



Universidad Tecnológica de Querétaro

INGENIERÍA EN DESARROLLO Y GESTIÓN DE SOFTWARE

Materia:

Seguridad en el Desarrollo de Aplicaciones

Maestro:

Gerardo Ramírez Villarreal

Grupo:

IDGS17

Nombre Alumno:

Luis Eduardo Rios Cervantes

Trabajo:

SEGG-U1-P1 — OWASP Top 10: Investigación y análisis de vulnerabilidades

Querétaro, Qro. 18 de Mayo de 2026

Tabla comparativa de las 10 vulnerabilidades OWASP Top 10 2025

Nombre	Descripción	Ejemplo	Impacto Potencial	Método de mitigación
A01:2025 - Broken Access Control	Aplica políticas para que los usuarios no puedan actuar fuera de sus permisos asignados. Las fallas generalmente llevan a la divulgación no autorizada de la información, modificación o destrucción de todos los datos o al desempeño de una función comercial fuera de los límites del usuario.	La aplicación utiliza datos no verificados en una llamada SQL que accede a la información de la cuenta: <code>pstmt.setString(1, request.getParameter("acct"));</code> <code>ResultSet results = pstmt.executeQuery();</code>	Exposición de información confidencial a un actor no autorizado. Exposición de información confidencial a través de datos enviados. Falsificación de solicitudes del lado del servidor (SSRF). Falsificación de solicitudes entre sitios (CSRF).	Validar permisos en el servidor.
A02:2025 - Security Misconfiguration	La configuración incorrecta de seguridad ocurre cuando un sistema, aplicación o servicio en la nube se configura incorrectamente desde una perspectiva de seguridad, lo que crea vulnerabilidades.	La configuración del servidor de aplicaciones permite devolver a los usuarios mensajes de error detallados, como rastros de pila. Esto expone potencialmente información confidencial o fallas subyacentes, como versiones de componentes que se sabe que son vulnerables.	Encontrar y descargar las clases Java compiladas, para descompilar y realizar ingeniería inversa para ver el código. Exponer potencialmente información confidencial o fallas subyacentes, como versiones de componentes que se sabe que son vulnerables.	Implementar procesos de instalación seguros.
A03:2025 - Software Supply Chain Failures	Las fallas en la cadena de suministro de software son averías u otros compromisos en el proceso de creación, distribución o actualización de software. A menudo son causados por vulnerabilidades o cambios maliciosos en el código, las herramientas u otras dependencias de terceros en las que se basa el sistema.	Un proveedor confiable se ve comprometido con malware, lo que hace que sus sistemas informáticos se vean comprometidos cuando actualiza.	Ataques que siembran versiones maliciosas de paquetes populares. Una vulnerabilidad de ejecución remota de código de Struts 2, permite la ejecución de código arbitrario en el servidor, de infracciones importantes.	Crear un proceso de gestión de cambios o un sistema de seguimiento para realizar un seguimiento de los cambios.
A04:2025 - Cryptographic Failures	En términos generales, todos los datos en tránsito deben estar cifrados en la capa de transporte (Capa OSI 4). Los obstáculos anteriores, como el rendimiento de la CPU y la gestión de claves/certificados privados, ahora los manejan las CPU	La base de datos de contraseñas utiliza hashes simples o sin sal para almacenar las contraseñas de todos. Una falla en la carga de archivos permite a un atacante recuperar la base de datos de	Interceptar solicitudes para robar cookies de sesión del usuario. Uso de un generador de números pseudoaleatorios débil.	Clasificar y etiquetar datos procesados, almacenados o transmitidos por una aplicación.

	que tienen instrucciones diseñadas para acelerar el cifrado (por ejemplo: Soporte AES) y la gestión de claves privadas y certificados se simplifica mediante servicios como LetsEncrypt.org con los principales proveedores de la nube que brindan servicios de gestión de certificados aún más integrados para sus plataformas específicas.	contraseñas. Todos los hashes sin sal se pueden exponer con una tabla arcoíris de hashes precalculados. Las GPU pueden descifrar los hashes generados por funciones hash simples o rápidas, incluso si estuvieran salados.		Identifique qué datos son confidenciales según las leyes de privacidad, los requisitos reglamentarios o las necesidades comerciales.
A05:2025 - Injection	Una vulnerabilidad de inyección es una falla de la aplicación que permite que una entrada de usuario no confiable se envíe a un intérprete (por ejemplo, un navegador, una base de datos, la línea de comandos) y hace que el intérprete ejecute partes de esa entrada como comandos.	Una aplicación utiliza datos no confiables en la construcción de la siguiente llamada SQL vulnerable: String query = "SELECT * FROM accounts WHERE custID=" + request.getParameter("id") + ""; Un atacante modifica el valor del parámetro 'id' en su navegador para enviar: ' OR '1'=1. . Por ejemplo: http://example.com/app/accountView?id=' OR '1'=1 Esto cambia el significado de la consulta para devolver todos los registros de la tabla de cuentas.	Un atacante suministra: ' OR custID IS NOT NULL OR custID='. Esto omite el filtro y devuelve todas las cuentas. Un atacante suministra example.com; cat /etc/passwd para ejecutar comandos arbitrarios en el servidor.	La mejor manera de evitar la inyección requiere mantener los datos separados de los comandos y consultas.
A06:2025 - Insecure Design	El diseño inseguro es una categoría amplia que representa diferentes debilidades, expresadas como "diseño de control faltante o ineficaz" El diseño inseguro no es la fuente de todas las demás diez categorías de riesgo principales.	Un flujo de trabajo de recuperación de credenciales puede incluir "preguntas y respuestas", lo cual está prohibido por NIST 800-63b, OWASP ASVS y OWASP Top 10. No se puede confiar en las preguntas y respuestas como evidencia de identidad, ya que más de una persona puede conocer las respuestas. Esta funcionalidad debería eliminarse y reemplazarse por un diseño más seguro.	Los atacantes podrían modelar este flujo y probar si pueden encontrar un vector de ataque en la lógica empresarial de la aplicación, por ejemplo, reservando seiscientas entradas y todos los cines a la vez en unas pocas solicitudes, lo que provocaría una pérdida masiva de ingresos.	Establecer y utilizar un ciclo de vida de desarrollo seguro con profesionales de AppSec para ayudar a evaluar y diseñar controles relacionados con la seguridad y la privacidad

A07:2025 - Authentication Failures	Cuando un atacante puede engañar a un sistema para que reconozca como legítimo a un usuario no válido o incorrecto, esta vulnerabilidad está presente. Puede haber debilidades de autenticación si la aplicación:	La mayoría de los ataques de autenticación exitosos ocurren debido al uso continuo de contraseñas como único factor de autenticación. Una vez consideradas las mejores prácticas, la rotación de contraseñas y los requisitos de complejidad alientan a los usuarios a reutilizar contraseñas y utilizar contraseñas débiles. Se recomienda a las organizaciones que pongan fin a estas prácticas según NIST 800-63 y que impongan el uso de autenticación multifactor en todos los sistemas importantes.	Permite ataques automatizados como el relleno de credenciales, donde el atacante tiene una lista violada de nombres de usuario y contraseñas válidos. Permite la fuerza bruta u otros ataques automatizados y programados que no se bloquean rápidamente.	Siempre que sea posible, implemente y haga cumplir el uso de autenticación multifactor para evitar ataques automatizados de relleno de credenciales, fuerza bruta y reutilización de credenciales robadas.
A08:2025 - Software or Data Integrity Failures	Las fallas de integridad del software y de los datos se relacionan con código e infraestructura que no protegen contra código o datos no válidos o no confiables que se tratan como confiables y válidos.	Cuando una aplicación depende de complementos, bibliotecas o módulos de fuentes, repositorios y redes de distribución de contenido (CDN) que no son de confianza. Una canalización de CI/CD insegura sin consumir ni proporcionar comprobaciones de integridad del software puede generar la posibilidad de acceso no autorizado, código inseguro o malicioso o compromiso del sistema.	Cualquier persona con acceso a la infraestructura del proveedor de soporte puede robar las cookies de todos sus usuarios.	Utilice firmas digitales o mecanismos similares para verificar que el software o los datos provengan de la fuente esperada y no hayan sido alterados.
A09:2025 - Security Logging and Alerting Failures	Sin registro y monitoreo, no se pueden detectar ataques e infracciones, y sin alertas es muy difícil responder rápida y eficazmente durante un incidente de seguridad. En cualquier momento se produce un registro insuficiente, un seguimiento continuo, una detección y una alerta para iniciar respuestas activas	Una importante aerolínea india sufrió una violación de datos que involucró más de diez años de datos personales de millones de pasajeros, incluidos datos de pasaportes y tarjetas de crédito. La violación de datos ocurrió en un proveedor externo de alojamiento en la nube, quien notificó	Persistencia del atacante	Asegúrese de que todas las fallas de inicio de sesión, control de acceso y validación de entrada del lado del servidor puedan registrarse

		la violación a la aerolínea después de algún tiempo.		con suficiente contexto de usuario para identificar cuentas sospechosas o maliciosas y conservarse durante el tiempo suficiente para permitir un análisis forense retrasado.
A10:2025 - Mishandling of Exceptional Conditions	El mal manejo de condiciones excepcionales en el software ocurre cuando los programas no logran prevenir, detectar y responder a situaciones inusuales e impredecibles, lo que provoca fallas, comportamientos inesperados y, a veces, vulnerabilidades. Esto puede implicar una o más de las siguientes 3 fallas; la aplicación no evita que ocurra una situación inusual, no identifica la situación tal como está sucediendo y/o responde mal o no responde en absoluto a la situación posterior.	El agotamiento de recursos debido al mal manejo de condiciones excepcionales (denegación de servicio) podría deberse a que la aplicación detecta excepciones cuando se cargan archivos, pero no libera recursos correctamente después. Cada nueva excepción deja los recursos bloqueados o no disponibles hasta que se agoten todos los recursos.	Exposición de infraestructura	Debemos 'captar' cada posible error del sistema directamente en el lugar donde ocurre y luego manejarlo (lo que significa hacer algo significativo para resolver el problema y asegurarnos de recuperarnos del problema).

2 casos reales por vulnerabilidad con contexto

A03: Software Supply Chain Failures

El compromiso de SolarWinds de 2019 que llevó a que aproximadamente 18.000 organizaciones se vieran comprometidas.

El robo de Bybit de 1.500 millones de dólares en 2025 fue causado por un ataque a la cadena de suministro en el software de billetera que solo se ejecutaba cuando se utilizaba la billetera de destino.

A02: Cryptographic Failures

En 2019 la empresa Equifax tenía una vulnerabilidad en los datos personales, ya que estaban expuestos sin la protección adecuada.

En 2012 la empresa LinkedIn tenía una vulnerabilidad en las contraseñas, ya que estaban siendo almacenadas con hash inseguro.

Código vulnerable vs seguro de 3 vulnerabilidades

A03: Injection

En el año 2011 la empresa Sony sufrió un ataque SQL Injection lo cual comprometió bases de datos.

Código Vulnerable

```
query = "SELECT * FROM users WHERE user = " + username + """;  
database.execute(query);
```

Código seguro

```
query = "SELECT * FROM users WHERE user = ?";  
database.execute(query, [username]);
```

A07: Identification and Authentication Failures

En el año 2014 la empresa Yahoo tuvo una demanda por robo masivo de cuentas

Código Vulnerable

```
if(password == "admin123"){  
    login();  
}
```

Código seguro

```
hashed = bcrypt.compare(password, storedHash);  
if(hashed){  
    login();  
}
```

A10: Server-Side Request Forgery (SSRF)

En el año 2021 la empresa Microsoft fue vulnerada en SSRF los cuales manejan servicios cloud internos

Código Vulnerable

```
fetch(userURL);
```

Código seguro

```
if(allowedDomains.includes(userURL.domain)){  
    fetch(userURL);  
}
```

Ranking personal de las 5 vulnerabilidades más críticas

1. Injection

La considero la más peligrosa porque puede comprometer completamente una base de datos con un solo parámetro vulnerable, además, sigue siendo extremadamente común en aplicaciones mal desarrolladas.

2. Broken Access Control

Muchas aplicaciones modernas fallan en validar permisos correctamente y esto le permite a los usuarios, acceder directamente a información privada o funciones administrativas sin necesidad de explotar técnicas avanzadas.

3. Vulnerable Components

Actualmente casi todas las aplicaciones dependen de librerías externas y una sola dependencia vulnerable puede comprometer miles de sistemas simultáneamente, como ocurrió con Log4Shell.

4. SSRF

SSRF se ha vuelto muy crítica debido al crecimiento de infraestructura Cloud, permite acceder a recursos internos y metadatos sensibles que normalmente no deberían ser públicos.

5. Security Logging and Monitoring Failures

Muchas empresas son comprometidas durante meses sin darse cuenta, aunque no es una vulnerabilidad directa de ejecución, amplifica enormemente el impacto de cualquier ataque.

Conclusión sobre la importancia del OWASP Top 10

Considero que OWASP Top 10 es una de las herramientas más importantes dentro de la seguridad informática, porque analiza de manera detallada las vulnerabilidades más explotadas en aplicaciones web reales. Como futuro Ingeniero en desarrollo y gestión de software, considero muy importante conocer estas amenazas, ya que no solo ayuda a comprender cómo funcionan los ataques, sino también a crear aplicaciones seguras desde el principio de la planeación, diseño y desarrollo. Al realizar la tabla comparativa de las 10 vulnerabilidades, me di cuenta de que la mayoría de ataques exitosos ocurren porque las organizaciones no siguen buenas prácticas de seguridad por ser consideradas “simples”, como la validación de entradas, la autenticación robusta o el monitoreo constante. Además,

el crecimiento de servicios Cloud y arquitecturas modernas ha provocado que vulnerabilidades como SSRF o fallos de integridad sean cada vez más peligrosas. Considero que en mi práctica profesional aplicaría este conocimiento implementando validaciones seguras, autenticación multifactor, uso de consultas parametrizadas a la base de datos, monitoreo y actualización continuo de las dependencias. También considero importante periódicamente realizar auditorías de seguridad y un análisis de amenazas desde la fase de diseño para reducir vulnerabilidades antes de que el software salga a producción. Esta investigación me ayudó a desarrollar una mentalidad preventiva.

Referencias

Temple-Raston, D. (2021, April 16). A “Worst nightmare” cyberattack: The untold story of the SolarWinds hack. *NPR*.

<https://www.npr.org/2021/04/16/985439655/a-worst-nightmare-cyberattack-the-untold-story-of-the-solarwinds-hack>